



Autenticación

- 
- > Qué es la Autenticación?
 - > Login basado en contraseña
 - > Brute Force Protection
 - > Multi Factor Authentication (MFA)
 - > Vulnerabilidades en otros mecanismos
 - > Herramientas

> Qué es la Autenticación?

- > Login basado en contraseña
- > Brute Force Protection
- > Multi Factor Authentication (MFA)
- > Vulnerabilidades en otros mecanismos
- > Herramientas

Qué es la Autenticación?

- > La autenticación es el proceso de verificar la identidad de un usuario o cliente determinado.
- > Implica asegurarse de que realmente alguien sea quien dice ser.
- > Los sitios web están expuestos a cualquier persona que esté conectada a Internet.
- > Por lo tanto, los mecanismos de autenticación sólidos, son un aspecto integral de la seguridad web efectiva



Factores de autenticación

- > Hay tres factores de autenticación en los que se pueden clasificar los diferentes tipos de autenticación:
 - **Algo que sabes**, como una contraseña o la respuesta a una pregunta de seguridad. A veces se los denomina "factores de conocimiento".
 - **Algo que tienes**, es decir, un objeto físico como un teléfono móvil o una tarjeta de seguridad. Estos a veces se denominan "factores de posesión".
 - **Algo que sos o haces**, por ejemplo, tus datos biométricos o patrones de comportamiento. En ocasiones, se denominan "factores de inherencia".
- > Todos los mecanismos de autenticación se basan en tecnologías que pueden verificar uno o más de estos factores.



Diferencia entre autenticación y autorización

- > La **autenticación** es el proceso de verificar que un usuario realmente es quien dice ser.
- > La **autorización** implica verificar si un usuario puede hacer algo.
- > En el contexto de un sitio web o aplicación web, la autenticación determina si alguien que intenta acceder al sitio con el nombre de usuario Carlos123 es realmente la misma persona que creó la cuenta.
- > Una vez autenticado Carlos123, sus privilegios determinan que es lo que puede hacer, es decir, a que está autorizado dentro del sistema.

Vulnerabilidades de autenticación

- > Conceptualmente las vulnerabilidades de autenticación son de las más sencillas de comprender.
- > Sin embargo, están entre las más críticas debido a la relación obvia entre autenticación y seguridad.
- > Además de permitir potencialmente a los atacantes el acceso directo a la funcionalidad y los datos confidenciales, también exponen una superficie de ataque adicional para futuras vulnerabilidades.
- > Por esta razón, aprender a identificar y aprovechar las vulnerabilidades de autenticación, incluido cómo eludir las medidas de protección comunes, es una habilidad fundamental.

Cómo surgen las vulnerabilidades de autenticación?

- > En términos generales, la mayoría de las vulnerabilidades en los mecanismos de autenticación surgen de una de estas dos formas:
 - Los mecanismos de autenticación son **débiles** porque no protegen adecuadamente contra los **ataques de fuerza bruta**.
 - Las **fallas lógicas o la codificación deficiente** en la implementación permiten a un atacante eludir por completo los mecanismos de autenticación. Esto a veces se denomina **autenticación rota (broken authentication)**.

Impacto de ésta vulnerabilidad

- > El impacto de las vulnerabilidades de autenticación puede ser **crítico**.
- > Un atacante que explota esta vulnerabilidad, tendrá acceso a todos los datos y funciones que tiene la cuenta comprometida:
 - Si se compromete una cuenta de >podrían tomar el control total de la aplicación y potencialmente obtener acceso a la infraestructura interna.
 - Si la cuenta tiene **pocos privilegios** el atacante quizá puede acceder a datos confidenciales.
 - Y si la cuenta **no tiene privilegios**, el atacante podrá acceder a páginas adicionales, proporcionando una superficie de ataque adicional.
- > Ciertos ataques de alto impacto son posibles sólo desde páginas internas de la aplicación

Vulnerabilidades en los mecanismos de autenticación

- > Existen muchas formas diferentes de atacar a los mecanismos de autenticación.
- > En el contexto de esta materia vamos a comentar las siguientes:
 - Vulnerabilidades en **inicio de sesión basado en contraseñas**.
 - Vulnerabilidades en **sistemas de autenticación multifactor**.
 - Vulnerabilidades en **otros mecanismos de autenticación**.

Gestión de la sesión

> Mecanismo que permite **mantener el estado autenticado** de un usuario entre requests HTTP.

Componentes clave	Riesgos	Buenas prácticas
• Session ID (token único) • Cookies (principal método de transporte) • Timeouts: Idle timeout , Absolute timeout	• Session ID predecible • No expiración de sesión • Transmisión sin HTTPS	• Generar IDs aleatorios y largos • Usar cookies con flags: HttpOnly, Secure, SameSite • Regenerar sesión tras login (session fixation defense) • Invalidar sesión en logout

- > Qué es la Autenticación?
- > Login basado en contraseña
- > Brute Force Protection
- > Multi Factor Authentication (MFA)
- > Vulnerabilidades en otros mecanismos
- > Herramientas

Introducción

- > En los sitios web donde el inicio de sesión es basado en contraseñas, generalmente los usuarios se auto registran o, un administrador les asigna una cuenta.
- > Generalmente, esta cuenta está asociada con un nombre de usuario único y una contraseña secreta, que el usuario ingresa en un formulario de inicio de sesión para autenticarse.
- > En este escenario, el mero hecho de conocer la contraseña secreta se toma como prueba suficiente de la identidad del usuario.
- > En consecuencia, la seguridad del sitio web se verá comprometida si un atacante puede obtener o adivinar las credenciales de inicio de sesión de otro usuario.

Ataques fuerza bruta

- > Un ataque de fuerza bruta ocurre cuando un atacante utiliza un sistema de prueba y error en un intento de adivinar las credenciales de usuario válidas.
- > Estos ataques **suelen automatizarse** mediante listas de palabras de nombres de usuario y contraseñas.
- > La automatización de este proceso, especialmente mediante el uso de herramientas dedicadas, permite a un atacante realizar una gran cantidad de intentos de inicio de sesión a alta velocidad.

Ataques fuerza bruta

- > Tener en cuenta que un atacante podría utilizar información disponible públicamente para ajustar el ataque.
- > Esto aumenta considerablemente la eficacia de estos ataques.
- > Los sitios web que dependen del inicio de sesión basado en contraseña como único método para autenticar a los usuarios pueden ser muy vulnerables si no implementan una protección suficiente contra la fuerza bruta.

Fuerza bruta basada en nombres de usuario

- > Los nombres de usuario son especialmente fáciles de adivinar si se ajustan a un patrón reconocible (Ej: un email).
- > El formato **firstname.lastname@somecompany.com** es muy común en las organizaciones.
- > A veces incluso se crean cuentas con muchos privilegios utilizando nombres de usuario predecibles, tales como: **admin** o **administrator**.

Entropía

- > El concepto de **entropía** fue desarrollado luego de observar que una cierta cantidad de energía liberada de reacciones de combustión siempre se pierde debido a la disipación o a la fricción y por lo tanto no se transforma en trabajo útil.
- > Los primeros motores de calor como el Thomas Savery (1698), la máquina de Newcomen (1712) y el Cugnot de vapor de tres ruedas (1769) eran ineficientes, dado que solo el 2% de la energía de entrada producía trabajo útil
- > El resto de la energía útil se disipaba o se perdía en lo que parecía un estado de aleatoriedad inconmensurable.
- > Durante los próximos dos siglos los físicos investigaron este enigma de la energía perdida.

Entropía

- > En la década de 1850, Rudolf Clausius estableció el concepto de sistema termodinámico y postula la tesis de que en cualquier proceso irreversible una pequeña cantidad de energía térmica se disipa gradualmente a través de la frontera del sistema.
- > Clausius siguió desarrollando sus ideas de la energía perdida, y acuñó el término «entropía».
- > Durante el próximo medio siglo se llevó a cabo un mayor desarrollo, y más recientemente el concepto de entropía ha encontrado aplicación en el campo análogo de pérdida de datos en los sistemas de transmisión de información.
- > Además se aplica en contraseñas, cuanto más aleatorias son, se dice que tienen más entropía.

Fuerza bruta basada en contraseñas

- > Las contraseñas de usuario también son **susceptibles** a ataques de fuerza bruta.
- > La dificultad varía según la **robustez** de la contraseña.
- > Muchos sitios web adoptan algún tipo de política de contraseñas, lo que obliga a los usuarios a crear contraseñas de alta entropía que son, al menos en teoría, más difíciles de descifrar utilizando fuerza bruta.
- > Por lo general, esto implica hacer cumplir contraseñas con:
 - Un número mínimo de caracteres.
 - Letras minúsculas y mayúsculas.
 - Al menos un carácter especial (# \$ & ! *)

Fuerza bruta basada en contraseñas

- > Estas contraseñas de **alta entropía** muchas veces son difíciles de descifrar sólo para las computadoras.
- > En lugar de crear una contraseña segura con una combinación aleatoria de caracteres, los usuarios introducen involuntariamente una debilidad en el sistema: intentan ingresar una contraseña que pueden recordar.
- > Como resultado se obtienen contraseñas que se ajustan a la política pero que resultan ser débiles:
 - Mypassword1!
 - Myp4\$\$w0rd

Enumeración de nombres de usuario

- > Se produce cuando podemos observar cambios en el comportamiento del sitio web que nos permiten identificar si un nombre de usuario es válido.
- > Generalmente ocurre en la página de inicio de sesión:
 - Cuando ingresamos un nombre de usuario válido pero una contraseña incorrecta.
 - En los formularios de registro cuando ingresa un nombre de usuario que ya está en uso.
- > Esta técnica nos permite generar rápidamente una pequeña lista de nombres de usuario válidos.
- > De esta forma se reduce en gran medida el tiempo y el esfuerzo necesarios para forzar un inicio de sesión.

Enumeración de nombres de usuario con STATUS CODES

- > Durante un ataque de fuerza bruta debemos revisar el código de estado HTTP devuelto por la aplicación.
- > Probablemente, para la mayoría de los request sea el mismo dado que serán intentos de inicio de sesión inválidos.
- > Si algún request devuelve un código de estado diferente podría significar que el nombre de usuario era correcto.
- > Es una buena práctica que los sitios web devuelvan siempre el mismo código de estado independientemente del resultado, pero esta práctica no siempre se sigue.

Enumeración de nombres de usuario con ERROR MESSAGES

- > A veces, el mensaje de error devuelto es diferente dependiendo de si el nombre de usuario Y la contraseña son incorrectos o solo la contraseña era incorrecta.
- > Es una buena práctica que los sitios web usen mensajes genéricos idénticos en ambos casos, pero a veces aparecen pequeños errores de escritura.
- > Un solo carácter fuera de lugar hace que los dos mensajes sean distintos, incluso en los casos en que el carácter no es visible en la página renderizada.

Enumeración de nombres de usuario con TIME RESPONSES

- > Si la mayoría de los request se gestionaron con un tiempo de respuesta similar, cualquiera que se desvíe de este tiempo podría sugerir que algo diferente estaba sucediendo detrás de escena.
- > Esta es otra indicación de que el nombre de usuario adivinado podría ser correcto.
- > Ejemplo:
 - Un sitio web solo puede verificar si la contraseña es correcta si el nombre de usuario es válido.
 - Este paso adicional puede provocar un ligero aumento en el tiempo de respuesta.
 - Esto puede ser muy sutil, pero un atacante puede hacer que este retraso sea más obvio ingresando una contraseña excesivamente larga que el sitio web tarda mucho más en manejar.

Hashing

> Proceso de transformar una contraseña en un **valor irreversible**.

Componentes clave	Riesgos	Buenas prácticas
Hash $\neq$ cifrado (no se puede revertir)	Uso de hashes rápidos (MD5, SHA1)	- Usar algoritmos de hash adaptativo: bcrypt, argon2, scrypt - Nunca almacenar contraseñas en texto plano

- > Qué es la Autenticación?
- > Login basado en contraseña
- > Brute Force Protection
- > Multi Factor Authentication (MFA)
- > Vulnerabilidades en otros mecanismos
- > Herramientas

Cómo podemos protegernos?

- > Probablemente, un ataque de fuerza bruta implique muchas peticiones fallidas antes de comprometer una cuenta.
- > Por consiguiente, la protección de fuerza bruta gira en torno a intentar que la automatización de este proceso sea lo más complicada posible.
- > Las dos formas más comunes de prevenir ataques de fuerza bruta son:
 - Bloquear la cuenta a la que el usuario remoto intenta acceder si realiza demasiados intentos fallidos de inicio de sesión
 - Bloquear la dirección IP del usuario si realiza demasiados intentos de inicio de sesión en un período corto de tiempo.
- > Ambos enfoques ofrecen distintos grados de protección, pero ninguno es invulnerable, especialmente si se implementa con una lógica defectuosa.

Bloqueo de cuentas

- > Podríamos **bloquear la cuenta** si se cumplen ciertos criterios sospechosos tales como un número determinado de intentos fallidos de inicio de sesión.
- > Pero a tener cuidado con esto: al igual que con los errores de inicio de sesión normales, las respuestas del servidor que indican que una cuenta está bloqueada también pueden ayudar al atacante a enumerar los nombres de usuario.
- > Además, bloquear la cuenta ofrece protección limitada cuando el ataque está enfocado en una cuenta específica.
- > Sin embargo, **no previene adecuadamente los ataques** de fuerza bruta en los que el atacante intenta obtener acceso a cualquier cuenta aleatoria..

Credential Stuffing

- > El bloqueo de cuentas tampoco protege contra ataques de tipo credential stuffing (relleno de credenciales).
- > Esto implica el uso de un **diccionario masivo de pares username:password** compuesto por credenciales de inicio de sesión genuinas robadas en violaciones de datos a sitios web.
- > Este ataque se basa en el hecho de que muchas personas reutilizan el mismo nombre de usuario y contraseña en varios sitios web.
- > El bloqueo de cuenta no protege contra este ataque porque cada nombre de usuario solo se intenta una vez.
- > Es particularmente peligroso porque a veces se puede comprometer muchas cuentas diferentes con un solo ataque automatizado.

- > Qué es la Autenticación?
- > Login basado en contraseña
- > Brute Force Protection
- > Multi Factor Authentication (MFA)
- > Vulnerabilidades en otros mecanismos
- > Herramientas

Introducción

- > Es cada vez más común ver autenticación de dos factores (2FA) obligatoria u opcional basada en algo que el usuario sabe y algo que tiene.
- > Esto generalmente requiere que los usuarios ingresen una contraseña tradicional y un código de verificación temporal de un dispositivo físico fuera de banda.
- > Lógicamente, la autenticación de doble factor es más segura que la autenticación de un solo factor.
- > Sin embargo, como con cualquier medida de seguridad, es tan segura como su implementación.

2FA

- > La autenticación de dos factores mal implementada puede superarse, o incluso omitirse por completo, al igual que la autenticación de factor único.
- > También vale la pena señalar que todos los beneficios de la autenticación multifactor solo se logran verificando múltiples factores diferentes.
- > La 2FA basada en correo electrónico es un ejemplo. Aunque el usuario debe proporcionar una contraseña y un código de verificación, acceder al código solo depende de que conozca las credenciales de inicio de sesión de su cuenta de correo electrónico.

2FA vs MFA

	2FA	MFA
Qué es?	Es un subconjunto específico de la MFA que utiliza dos factores obligatorios, que pueden ser de la misma categoría (ej. contraseña + PIN) o de categorías diferentes (ej. contraseña + código SMS), aunque lo ideal es que sean distintos	Es el concepto más amplio que abarca dos o más factores que deben ser de categorías diferentes (conocimiento, posesión, inherencia), permitiendo la adición de capas como biometría o geolocalización para mayor seguridad

2FA vs MFA

	2FA	MFA
Número y diversidad de factores	exige dos factores que pueden ser de la misma categoría (por ejemplo, contraseña y PIN, ambos "algo que sabe")	exige que los factores pertenezcan a categorías distintas (como "algo que sabe", "algo que tiene" y "algo que eres") para garantizar una mayor protección
Nivel de seguridad	La MFA es generalmente más segura que la 2FA porque añade capas adicionales de verificación (como biometría o geolocalización) que dificultan el acceso no autorizado incluso si un factor ha sido comprometido	
Casos de uso	es común en aplicaciones personales y negocios pequeños por su simplicidad	se recomienda para entornos corporativos críticos, cumplimiento normativo estricto y protección de datos sensibles que requieren múltiples verificaciones

Software & hardware tokens

- > El usuario suele leer los códigos de verificación desde un dispositivo físico de algún tipo.
- > Muchos sitios web de alta seguridad brindan a los usuarios un dispositivo dedicado para este propósito, como el token RSA.
- > Además de estar diseñados específicamente para la seguridad, estos dispositivos dedicados también tienen la ventaja de generar el código de verificación directamente.
- > También es muy común que los sitios web utilicen una aplicación móvil dedicada, como las apps del tipo **Authenticator**

OTP por SMS

- > Algunos sitios web envían códigos de verificación al teléfono móvil de un usuario como mensaje de texto.
- > Si bien esto sigue siendo un factor del tipo **algo que tienes**, puede ser abusado en cuanto al uso.
- > En primer lugar, el código se transmite a través de SMS en lugar de ser generado por el propio dispositivo: esto crea la posibilidad de que el código sea interceptado.
- > También existe el riesgo de **intercambio de SIM**, por el cual un atacante obtiene de manera fraudulenta una tarjeta SIM con el número de teléfono de la víctima:
 - El atacante recibiría todos los mensajes SMS enviados a la víctima, incluido el que contenía su código de verificación.

- > Qué es la Autenticación?
- > Login basado en contraseña
- > Brute Force Protection
- > Multi Factor Authentication (MFA)
- > Vulnerabilidades en otros mecanismos
- > Herramientas

Cifrado de cookie

- > Algunos sitios web asumen que si la cookie está encriptada de alguna manera, no se podrá adivinar incluso si usa valores estáticos.
- > Si bien esto puede ser cierto si se hace correctamente, "encriptar" la cookie usando una codificación bidireccional simple como Base64 no ofrece protección alguna.
- > Incluso el uso de un cifrado adecuado con una función hash unidireccional no es completamente a prueba de balas.
- > Si el atacante es capaz de identificar fácilmente el algoritmo de hash y no se utiliza un salting, puede potencialmente aplicar fuerza bruta a la cookie simplemente haciendo hash en sus listas de palabras.
- > Otra opción es buscar listas de contraseñas conocidas y sus hashes.

Envío de contraseñas por correo electrónico

- > El correo electrónico no se considera seguro.
- > Las bandejas de entrada son persistentes y no están diseñadas para el almacenamiento seguro de información confidencial.
- > Además, muchos usuarios también sincronizan automáticamente su bandeja de entrada entre varios dispositivos a través de canales inseguros.

Session attacks

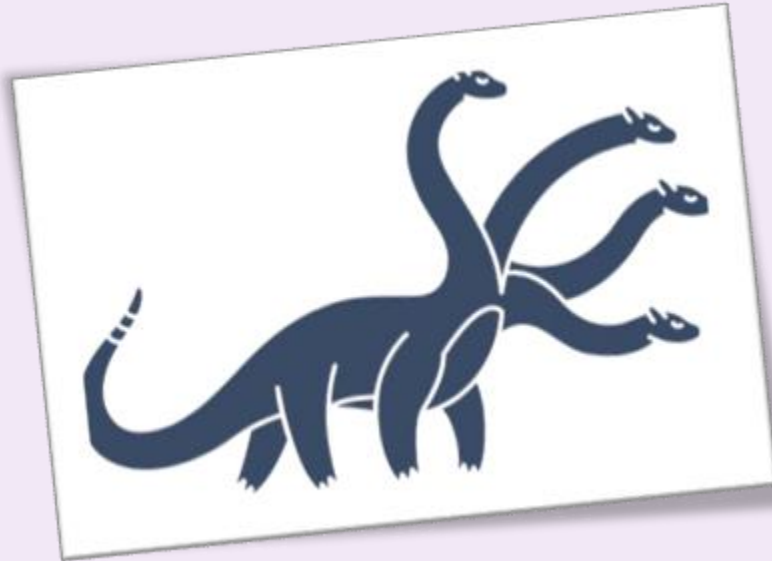
> Ataques que buscan robar o abusar de una sesión válida

Tipos principales	Vectores típicos	Mitigaciones
• Session Hijacking: Robo de cookie (XSS, MITM) • Session Fixation: Forzar al usuario a usar un session ID conocido • Replay attacks: Reutilización de tokens capturados	• XSS • Redes WiFi inseguras • Falta de HTTPS	• HTTPS obligatorio • Rotación de session ID • Validación de contexto: IP / User-Agent (con cautela) • Protección contra XSS • Cookies seguras (HttpOnly, Secure)

- > Qué es la Autenticación?
- > Login basado en contraseña
- > Brute Force Protection
- > Multi Factor Authentication (MFA)
- > Vulnerabilidades en otros mecanismos
- > Herramientas

Hydra

> <https://github.com/vanhauser-thc/thc-hydra>



Wfuzz

> <https://github.com/xmendez/wfuzz>



Dudas?

